exec.txt
TXT 56.57KB

Analise o arquivo em anexo passo a passo e determine ao final: este arquivo é benigno ou é um malware?

Found 11 web pages

Com base na análise passo a passo do conteúdo do arquivo, a conclusão é: **este arquivo é um malware altamente perigoso**, especificamente um **worm de botnet SSH** com funcionalidades de propagação automática, verificação de credenciais e persistência.

🔍 Evidências principais da análise

1. Comportamento malicioso claramente definido
O arquivo contém a lógica completa de um worm: utiliza `masscan` para escanear em larga escala portas SSH abertas (22, 5522), e então realiza tentativas de login por força bruta usando nomes de usuário e senhas predefinidos (`root` / `LeitboGi0ro` , `123@@@`) . Após o sucesso, ele se propaga através de SFTP e executa remotamente o script `bendi.py` , transformando a máquina invadida em um novo nó de verificação. [1] [2]

2. Persistência e ocultação
O script instala os serviços `scan-runner.service` e `file-monitor.service` no sistema, garantindo que o programa seja reiniciado automaticamente após a reinicialização do sistema. Os arquivos são colocados em diretórios ocultos como `/usr/lib/.sysd-scan/` e `/var/lib/.sysd-data/` , imitando arquivos normais do sistema para evitar a detecção do usuário . [1] [2]

3. Infraestrutura de comando e controle (C2) confirmada como maliciosa
O código contém o endereço `sou.pp.ua` e `del.sou.pp.ua` , que foram sinalizados por várias organizações de segurança, incluindo URLhaus e VirusTotal, como infraestrutura de distribuição de malware . O script também se comunica com o servidor Telegram do atacante para enviar relatórios, característica típica de malwares de botnet. [3] [5] [7]

4. Referências cruzadas com amostras conhecidas
Análises públicas de segurança cibernética mostram que o `bendi.py` é um malware ativo recentemente, com comportamento e infraestrutura (como o domínio `sou.pp.ua`)

altamente consistentes com este arquivo, sendo utilizado para ataques de força bruta SSH e recrutamento de botnet . [1] [2]

⚠️ Aviso de segurança

Se este arquivo foi encontrado em seu servidor, isso indica que o sistema pode ter sido comprometido. Recomenda-se **desconectar imediatamente a rede**, verificar serviços e arquivos ocultos suspeitos, e realizar uma auditoria completa de segurança e reinstalação do sistema. Se for apenas um arquivo recebido, **não execute nem abra** sob nenhuma circunstância.

11 web pages

Qual é a categoria principal deste malware?

Found 9 web pages

A categoria principal deste malware é **worm de botnet SSH (verme de botnet SSH)**, que também possui funcionalidades de **mineração de criptomoedas** e **estabelecimento de persistência (backdoor)**.

🦠 Base para a classificação

- **Verminização e propagação automática**: Este é o seu comportamento mais central. O script utiliza `masscan` para escanear a Internet em busca de portas SSH abertas e utiliza credenciais predefinidas para realizar ataques de força bruta. Após o login bem-sucedido, ele se auto-replica e se espalha para o novo host, transformando o servidor comprometido num novo nó de escaneamento e ataque. [4] [6]
- **Mineração de criptomoedas**: Relatórios de análise de segurança indicam que, ao executar o `bendi.py` , ele também implantará programas de mineração de criptomoedas no servidor comprometido, utilizando os recursos da máquina vitimada para minerar. [3]
- **Estabelecimento de persistência (Backdoor)**: Para garantir que possa controlar o servidor a longo prazo, ele instala uma camada de persistência denominada `komari-monitor` (ou serviços com nomes semelhantes a serviços legítimos do sistema), garantindo que, mesmo após a reinicialização do servidor, o controle possa ser recuperado. [1] [6]

Resumindo, trata-se de um malware que visa servidores Linux/cloud, utilizando força bruta SSH para se autopropagar e, simultaneamente, realizando mineração de criptomoedas e estabelecendo backdoors para controle persistente.

9 web pages